

Week 6 - Advanced Security Audits & Final Deployment

Objective:

Conduct advanced security audits, ensure compliance with industry standards, and prepare the application for secure deployment.

Tasks Completed

Task	Description
Security Audits	The application was scanned using multiple auditing tools including OWASP ZAP , Nikto , and Lynis . All public routes, forms, headers, and authentication flows were tested. OWASP Top 10 checklist was used to ensure compliance.
OWASP ZAP Scan	Detected missing X-Frame-Options and CSP misconfigurations initially. These were fixed using Helmet middleware.
Nikto Scan	Nikto flagged directory listings and outdated server banners. These were resolved by adjusting Express headers and restricting public folder access.
Lynis Audit	Performed a system-wide audit on the Kali VM hosting the app. Recommended enabling automatic updates and improving permissions on log files.
Dependency & Container Security	Added npm audit fix to CI/CD pipeline and enabled GitHub Dependabot. Docker container was scanned using docker scan and trivy . Minor image vulnerabilities were patched and unused packages removed.
Final Penetration Testing	Full test was performed using Burp Suite , targeting CSRF, XSS, and IDOR. No exploitable vulnerabilities were found after applying prior fixes. A simulated reverse shell via Metasploit was attempted but failed due to patched input handling and firewall rules.

Summary of Tools and Fixes

Tool	Findings	Fix Implemented
------	----------	-----------------

OWASP ZAP	Missing security headers	Helmet configured with HSTS, XFO, CSP
Nikto	Open directory listing, server banner	Disabled listing, removed headers
Lynis	Update handling, file permissions	Enabled auto updates, hardened logs
Docker Scan	Minor image CVEs	Updated base image, removed unused packages
Burp Suite	Tested CSRF/XSS/IDOR	All tests passed due to earlier mitigations

Final Application Security Features

- **Rate Limiting** for login routes
- **CSRF Protection** using `csurf`
- **SQL Injection Protection** using parameterized queries
- **Security Headers** using Helmet
- **CORS Restrictions** to allow only trusted origins
- **Input Validation** and output encoding
- **Secure Session Management** using `express-session` with MongoStore
- **Dockerized Deployment** with a minimized secure image
- **CI/CD Pipeline** integrated with `npm audit` and dependency scanning